보안 장비 운용

KOREA
코리아IT아카데미학원



class	정보보안 산업기사 취득과정 A
name	조채언

목 차

Ⅰ. 보안 시스템 운영 상태 점검 보고서 ····· 3
가. 운영 절차서 구성 ····· 3
나. 주요 성능 지표 및 기준 ····· 6
다. 점검 도구 및 명령어 예시 ····· 7
라. 점검 결과 기록 및 보고 방안 ····· 8

Ⅱ. 최적의 보안 시스템 구성도 설계 및 구축 ····· 9
가. 보안 시스템 구축 구성도 작성 ····· 9
나. 보안 시스템을 안전하게 운영하기 위한 방법 ····· 10
다. 보안 시스템 운용 상태 분석 방법 ····· 11

Ⅲ. IDS/IPS을 이용하여 구현 ····· 12
가. White List 기반의 방화벽 구현 및 방화벽 정책 설명 ····· 12
나. IPS 기반 외부 네트워크의 내부 서버 Telnet 접속 차단 정책 구현 ····· 15
다. IDS/IPS 모니터링 및 탐지 시스템을 구동하는 스크립트 ····· 17
라. IDS/IPS 이용하여 악성코드 탐지 ····· 19

Ⅳ. 보안 시스템 장애 분석 및 대응 방안 보고서 ····· 26
가. 운영 현황 도식화 ····· 26
나. 장애 분석 ····· 27
다. 장애 유형별 대응 방안 ····· 27
라. 장애 보고서 작성 ····· 28
마. 재발 방지 대책 ····· 28

Ⅰ. 보안 시스템 운영 상태 점검 보고서

가. 운영 절차서 구성

(1) 적용 범위

- **방화벽 (Firewall)**
  서로 다른 네트워크를 지나는 트래픽을 정해진 보안 정책·규칙 집합을 기반으로 트래픽을 허용하거나 차단하는 기능을 수행하는 시스템이다.

- **침입 방지·침입 탐지 시스템 (Intrusion Prevention/Detection System)**
  공격 패턴을 저장하고 있는 데이터베이스와 컴퓨터 또는 네트워크에서 발생하는 이벤트들을 비교하여 침입 발생 여부를 탐지 및 차단하는 시스템을 말하며, 탐지만 수행하는 시스템이 침입 탐지 시스템이고, 탐지와 차단을 함께 수행하는 시스템이 침입 방지 시스템이다.

- **Anti-DDoS (Distributed Denial of Service)**
  TCP Syn Flooding, UDP Flodding, HTTP Slow Ioris 공격 등 다양한 DDoS 공격을 방어하는 DDoS 전용 보안 시스템이다.

- **Anti-APT (Advanced Persistent Threat)**
  ZeroDay 공격에 대응이 어려운 패턴 기반의 보안 시스템의 한계를 극복하기 위하여 가상 머신을 활용한 샌드박스(Sandbox)에서 직접 파일을 실행하여 악성 행위 수행 여부를 확인하여 악성 코드 여부를 탐지, 차단하는 보안 시스템이다.

- **웹 방화벽(Web Application Firewall)**
  OWASP(Open Web Application Security Project) Top 10 공격 등 웹 서비스를 대상으로 하는 외부 침입이나 공격을 탐지하고 대응하는 보안 시스템이다.

- **ESM(Enterprise Security Management)**
  각 기업이 도입하여 운영 중인 다양한 이기종의 보안 시스템을 통합적으로 운영·관리·관제하기 위한 보안 시스템이다.

(2) 점검 항목

점검 항목명	점검 사항	점검 결과
하드웨어 사용 현황	CPU, Memory, 인터페이스 Down 여부 등 하드웨어 현황	Pass / Fail
관리자 접속 기록	관리자 계정으로 최근 접속한 IP 및 시간 확인	Pass / Fail
최신 패턴 업데이트	최신 공격 패턴에 대한 업데이트	Pass / Fail
최신 취약점 확인	OpenSSL, SNMP, NTP 등 최신 취약점 발표 및 패치 적용 여부	Pass / Fail
불필요 서비스 여부	불필요한 서비스 동작 여부	Pass / Fail
Top 5 이벤트	악성 행위 호스트 Top 5에 대한 확인	Pass / Fail
백업 수행 여부	시스템 구성 파일 변경 및 백업 수행 주기에 따른 백업 수행 여부	Pass / Fail
이상 현상 발생 여부	기존 트렌드 대비 급격한 변화가 발생한 이벤트 존재 여부	Pass / Fail

(3) 주기 및 기준

- **일일 점검 :** 서비스 정상 여부
- **주간 점검 :** 보안 로그 요약 분석 및 임계치 초과 이력 확인
- **월간 점검 :** 패치 관리, 계정 권한 검토 및 정기 백업 수행 여부
- **긴급 점검 :** 장애/침해 발생 시 즉시 수행

(4) 역할 및 책임

- **보안 운영 담당자 :** 일일 모니터링 및 이상 탐지
- **시스템 관리자 :** 서버 및 네트워크 상태 유지
- **보안 관리자 :** 정책 검토 및 사고 대응
- **감사 담당자 :** 점검 결과 검토 및 감사

(5) 이상 대응 절차

(가) 탐지

운영 점검 과정에서 시스템 자원 사용률 증가, 비정상 트래픽 발생, 로그인 실패 급증, 악성코드 탐지, 서비스 중단 등 이상 징후를 확인한다. 이상 여부는 모니터링 시스템, 로그 분석 도구(SIEM), 백신/EDR 경고, 사용자 신고 등을 통해 탐지할 수 있으며, 사전에 정의된 임계치(KPI 기준)를 초과하는 경우 경고(Alert)를 발생시킨다. 탐지된 이상 항목은 발생 시간, 영향 대상 시스템, 증상 및 이벤트 로그를 즉시 기록하여 후속 분석에 활용한다.

(나) 보고

이상 상황이 확인되면 운영 담당자는 보안 관리자 및 시스템 관리자에게 즉시 상황을 전파한다. 보고 시에는 장애 또는 보안 사고의 발생 시간, 영향 범위, 현재 상태, 예상 위험도 및 긴급성을 포함하여 전달한다. 중요 시스템 장애나 침해 사고의 경우에는 비상 연락 체계를 가동하여 관련 부서 및 책임자에게 신속히 공유하며, 필요 시 경영진 보고까지 수행한다. 또한 보고 내용은 이메일, 메신저, 티켓 시스템 또는 장애 관리 시스템에 기록하여 추적 가능하도록 관리한다.

(다) 분석

보안 및 시스템 담당자는 수집된 로그와 이벤트 정보를 기반으로 이상 발생 원인을 분석한다. 원인 분석 과정에서는 시스템 로그 확인, 네트워크 패킷 분석, 프로세스 상태 점검, 악성코드 검사, 계정 사용 이력 확인 등을 수행한다. 분석 결과에 따라 서비스 차단, 계정 잠금, 네트워크 격리, 프로세스 재시작, 정책 변경 등 긴급 조치를 실시하여 피해 확산을 방지한다. 필요 시 백업 데이터를 활용한 복구 작업을 수행하며, 조치 과정과 결과를 모두 기록하여 향후 감사 및 재발 방지 자료로 활용한다.

(라) 사후 조치

장애 또는 보안 사고가 종료된 이후에는 재발 방지를 위한 후속 조치를 수행한다. 사고 발생 원인과 대응 과정을 종합적으로 검토하여 취약점 개선, 보안 정책 강화, 시스템 설정 변경, 패치 적용, 사용자 교육 등을 진행한다. 또한 사고 대응 결과와 영향도, 복구 현황, 개선 대책 등을 포함한 최종 보고서를 작성하여 관리 책임자 및 관련 부서에 공유한다. 사후 분석 결과는 운영 절차 및 대응 매뉴얼 개선에 반영하여 향후 동일한 문제가 발생했을 때 보다 신속하고 체계적으로 대응할 수 있도록 한다.

나. 주요 성능 지표 및 기준

성능 지표명	설명	기준(정상 범위)
CPS(Connection Per Second)	초당 처리 가능한 1개의 TCP 연결 수립 개수	80% 이하
TPS(Transaction Per Second)	초당 처리 가능한 HTTP(요청과 응답) 개수	80% 이하
PPS(Packet Per Second)	초당 처리 가능한 패킷의 개수	70% 이하
최대 처리율(Throughput)	초당 처리하는 작업의 개수	85% 이하
지연 시간(Latency)	하나의 작업을 처리하는 소요되는 시간	50ms 이하
동시 접속 개수(Concurrent Connections)	동시에 접속 가능한 최대 연결 개수	80% 이하

다. 점검 도구 및 명령어 예시

(1) CLI 기준 점검

Linux 서버 점검 명령어

```
# CPU/메모리 확인
top
htop
free –m

# 디스크 사용량 확인
df –h

# 네트워크 상태 확인
netstat -ant
ss –ant

# 로그 확인
tail –f /var/log/messages

# 보안 이벤트 확인
cat /var/log/secure

# 프로세스 상태
ps -ef
systemctl status firewalld
```

(2) GUI 기반 점검

도구	용도
SIEM 대시보드	통합 로그 분석
Zabbix / Grafana	시스템 모니터링
EDR 콘솔	악성코드 및 행위 탐지
Firewall 관리자 화면	정책 및 세션 상태 확인

라. 점검 결과 기록 및 보고 방안

(1) 점검표 예시

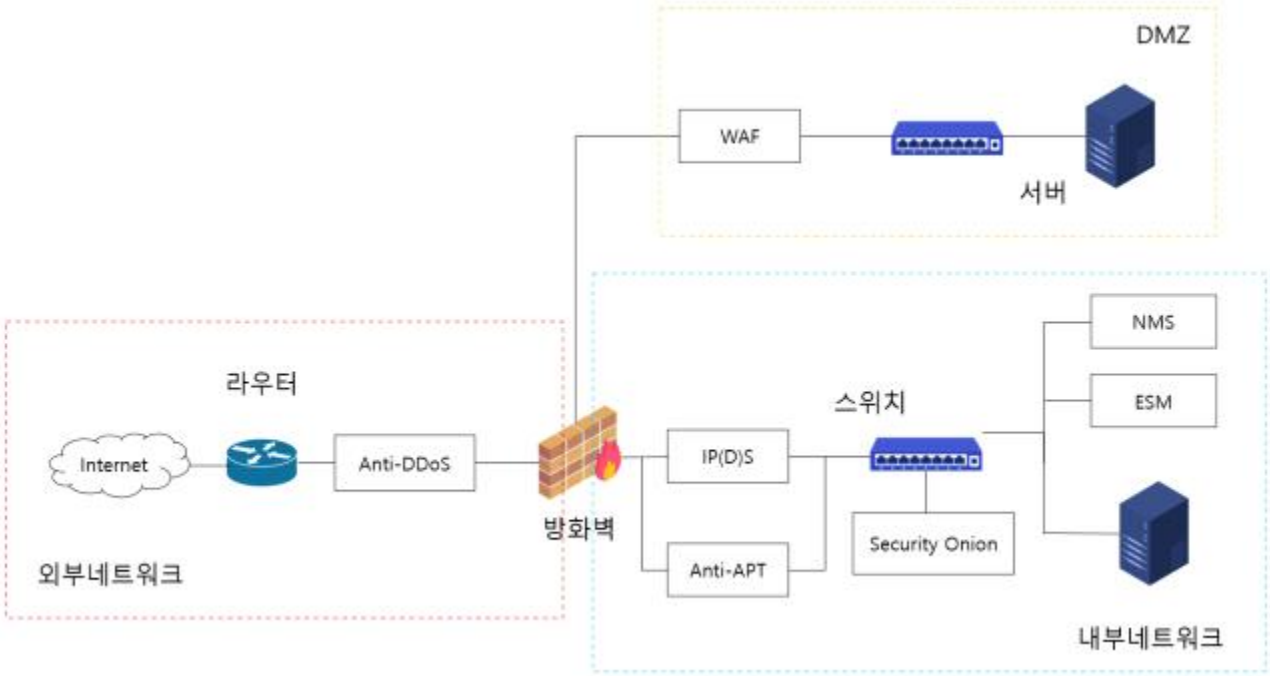
점검 일시	점검 항목	결과	조치 사항
2026-05-15 09:00	CPU 사용률	정상 (45%)	없음
2026-05-15 09:10	로그인 실패 횟수	주의 (7회)	계정 잠금 조치
2026-05-15 09:30	백신 상태	정상	최신 업데이트 완료
2026-05-15 10:00	실시간 로그 탐지	주의 (특정 외부 IP에서 과도한 ICMP 탐지 발생)	해당 IP(1.2.3.4) 일시 차단 정책 적용 후 모니터링 중
2026-05-15 10:30	스토리지 사용량	경고 (92%)	임시 파일 삭제 후 65%로 복구
2026-05-15 11:20	정기 백업 수행 여부	정상	없음

(2) 보고 방식 요약

점검 항목명	점검 사항	점검 결과
일일 점검	하드웨어(CPU, Memory 등) 사용 현황	Pass/Fail
	하드웨어 장애 여부 육안 점검	Pass/Fail
	이상 현상(보안 이벤트) 발생 유무	Pass/Fail
월간 점검	보안 시스템 보안 설정 - 계정, 접근 통제, 보안 패치 적용 여부 등	Pass/Fail
	불필요 서비스 여부 확인	Pass/Fail
분기/반기 점검	보안 정책 유효성 검증 - 불필요 정책, 비인가된 정책, Blacklist/Whitelist 유효성	Pass/Fail
	계정 유효성 상세 점검	Pass/Fail

Ⅱ. 최적의 보안 시스템 구성도 설계 및 구축

가. 보안 시스템 구축 구성도 작성



나. 보안 시스템을 안전하게 운영하기 위한 방법

(1) 계정 및 접근 통제

- **최소 권한 원칙:** 모든 운영자에게 업무 수행에 필요한 최소한의 권한만 부여합니다. (예: 단순 모니터링 요원은 읽기 전용 권한만 부여)
- **1인 1계정 원칙:** 공용 계정(admin, root 등) 사용을 금지하고, 개인별 계정을 발급하여 행위에 대한 책임 추적성을 확보합니다.
- **접근 IP 제한:** 보안 장비 설정 페이지(GUI/CLI)에 접속 가능한 IP를 관리자 단말기나 특정 보안 세그먼트로 제한합니다.

(2) 패스워드 및 인증 정책

- **복잡성 및 주기 설정:** 영문 대소문자, 숫자, 특수문자를 혼합한 8~12자리 이상의 비밀번호를 사용하며, 분기별(90일)로 변경을 강제합니다.
- **2단계 인증:** 관리자 로그인 시 패스워드 외에 OTP(One-Time Password)나 SMS 인증을 추가하여 계정 유출로 인한 2차 피해를 방지합니다.
- **임계치 설정:** 로그인 5회 실패 시 해당 계정을 일정 시간 동안 잠금 처리하여 무차별 대입 공격(Brute-force)을 차단합니다.

(3) 보안 정책 설정 및 변경 이력 관리

- **변경 승인 절차:** 정책 추가나 변경 시 '신청 → 검토 → 승인 → 적용'의 단계를 거치며, 임의 변경을 엄격히 금지합니다.
- **정기 정책 최적화:** 장기간 사용하지 않는 정책(Unused Rules)이나 중복된 정책을 주기적으로 전수 조사하여 삭제함으로써 장비 성능과 보안성을 높입니다.
- **이력 기록:** "누가, 언제, 왜, 어떤 정책을 변경했는지"에 대한 사유와 전/후 데이터를 기록하여 관리합니다.

(4) 로그 및 이벤트 모니터링

- **실시간 탐지 및 알림:** 침입 시도나 시스템 임계치(CPU/MEM) 초과 시 관리자에게 실시간 알림(Email, SMS, 메신저 등)이 전송되도록 설정합니다.
- **로그 통합 관리:** 장비 자체 저장소는 용량이 부족할 수 있으므로, 별도의 Syslog 서버나 SIEM(Security Onion 등)으로 로그를 전송하여 중앙 집중식으로 관리합니다.
- **무결성 보호:** 수집된 로그가 변조되지 않도록 읽기 전용 권한으로 관리하고 정기적으로 백업합니다.

(5) 백업 및 복원 체계

- **백업의 이중화:** 구성 파일(Config)과 운영 로그를 분리하여 백업하며, 로컬과 원격지(클라우드 또는 별도 서버)에 이중으로 저장합니다.
- **정기 복원 테스트:** 백업 파일이 실제로 정상 작동하는지 분기별로 가상 환경에 복구해 보는 복원 시뮬레이션을 수행합니다.
- **버전 관리:** 설정 변경 직전에 항상 현재 상태를 백업하여, 변경 후 문제가 발생했을 때 즉시 이전 상태로 되돌릴 수 있는 롤백(Roll-back) 대책을 마련합니다.

다. 보안 시스템 운용 상태 분석 방법

(1) 구성 관리

보안 시스템은 적절한 위치에 HA(High Availability, 고가용성) 등 안정성을 고려하여 구성되었으며, 절차에 따른 구성 변경을 수행하는지에 대한 여부, 구성 변경 후 시스템 현황 문서에 반영하여 항상 현행화하는지에 대하여 분석 후 평가를 수행한다.

(2) 정책 관리

승인에 의한 정책 변경을 수행하고 있으며, 불필요한 정책이 없는지에 대한 검증 작업이 수행되는지, 최신 공격 패턴이 업데이트 되는지, 정책에 대한 이력 관리는 잘되는지 등에 대하여 확인 분석 후 평가한다.

(3) 계정 및 패스워드 관리

관리자 기본 계정 및 패스워드 사용 유무나 불필요 계정 존재 유무, 로그인 실패 횟수 제한 등의 설정을 분석 후 평가한다.

(4) 접근 제어 관리

보안성 있는 프로토콜(ssh, https 등)을 사용하는지, 세션 타임아웃을 설정하였는지, 승인된 IP나 MAC을 통해서만 접근이 가능한지 등을 분석 후 평가를 수행한다.

(5) 로깅 및 모니터링 관리

로그 분석 효과성을 위한 NTP 설정 여부, 별도의 로그 관리 서버에 로그를 저장하기 위한 syslog 설정 여부, 주기적 로그 분석 여부, 운영자 작업 로그 등 로깅하는 수준의 적절성 등을 분석 후 평가한다.

(6) 보안 시스템 기능 관리

최소 서비스의 사용, 이상 징후 탐지 시 경고 설정, 장비 자원 사용량 경고, SNMP 설정 등 장비 특성별 부가 기능을 설정하였는지에 대하여 분석 후 평가를 수행한다.

Ⅲ. IDS/IPS을 이용하여 구현

가. White List 기반의 방화벽 구현 및 방화벽 정책 설명

1. 포트포워딩 설정

-A PREROUTING -d 10.0.0.222 -p TCP --dport 22 -j DNAT —to 10.0.0.200:22

: 외부 사용자가 10.0.0.222:22로 접속을 시도하면, 패킷의 목적지(Destination)를 실제 서버인 10.0.0.200:22로 바꾸라는 의미

-A POSTROUTING -d 10.0.0.200 -p TCP --dport 22 -j SNAT —to 10.0.0.222

: 패킷이 내부 서버인 10.0.0.200으로 전달될 때, 출발지(Source) 주소를 중계기인 10.0.0.222로 바꾸라는 의미

-> 10.0.0.222 장비가 일종의 게이트웨이(중계기) 역할을 수행하며, 자신에게 오는 SSH(22번 포트) 요청을 내부의 10.0.0.200 서버로 토스해 준다.

```
*nat
:PREROUTING ACCEPT [0:0]
:POSTROUTING ACCEPT [0:0]
:OUTPUT ACCEPT [0:0]
-A POSTROUTING -s 10.0.0.0/24 -o ens33 -j MASQUERADE
-A PREROUTING -d 10.0.0.222 -p TCP --dport 22 -j DNAT --to 10.0.0.200:22
-A POSTROUTING -d 10.0.0.200 -p TCP --dport 22 -j SNAT --to-source 10.0.0.222
COMMIT

*filter
:INPUT DROP [0:0]
:FORWARD ACCEPT [0:0]
:OUTPUT ACCEPT [66:8043]
-A INPUT -m state --state RELATED,ESTABLISHED -j ACCEPT
#-A FORWARD -j NFQUEUE --queue-num=4
-A INPUT -p icmp -j ACCEPT
-A INPUT -i lo -j ACCEPT
-A INPUT -p tcp -m state --state NEW -m tcp --dport 22 -j ACCEPT
-A INPUT -p tcp -m state --state NEW -m tcp --dport 80 -j ACCEPT
-A INPUT -p tcp -m state --state NEW -m tcp --dport 443 -j ACCEPT
#-A INPUT -j REJECT --reject-with icmp-host-prohibited
#-A FORWARD -j REJECT --reject-with icmp-host-prohibited
COMMIT
# Completed on Sun May 15 10:17:00 2022

"/etc/iptables/rules.v4" 25L, 863B
```

2. 포트포워딩 확인

10.0.0.222로 SSH 접속을 시도했을 때, 실제로는 10.0.0.200 서버의 roror 계정으로 로그인하게 된다.

```
root@kali:/home/kali# ssh roror@10.0.0.222
Welcome
roror@10.0.0.222's password:
Welcome Test Motd
Web console: https://roror.co.kr:9090/ or https://10.0.0.200:9090/

Last login: Wed May 20 18:35:46 2026 from 10.0.0.222
roror@roror:~$
```

3. 방화벽 구현

허용되지 않은 접근 요청 발생 시 ICMP 응답을 통해 접근 차단 여부를 확인할 수 있도록 설정하였다. 이를 통해 비인가 접근 탐지 및 네트워크 상태 확인이 가능하도록 구성하였다. 또한, 특정 IP 주소 또는 위험 포트에 대한 접근을 차단하였다. White List에 등록된 IP만 내부 서버 접근이 가능하도록 설정하여 불필요한 외부 접근을 제한하였다.

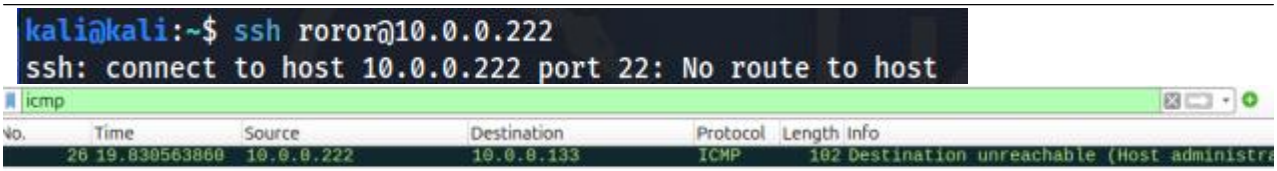
```
*nat
:PREROUTING ACCEPT [0:0]
:POSTROUTING ACCEPT [0:0]
:OUTPUT ACCEPT [0:0]
-A POSTROUTING -s 10.0.0.0/24 -o ens33 -j MASQUERADE
-A PREROUTING -d 10.0.0.222 -p TCP --dport 22 -j DNAT --to 10.0.0.200:22
-A POSTROUTING -d 10.0.0.200 -p TCP --dport 22 -j SNAT --to-source 10.0.0.222
COMMIT

*filter
:INPUT DROP [0:0]
:FORWARD ACCEPT [0:0]
:OUTPUT ACCEPT [66:8043]
-A INPUT -m state --state RELATED,ESTABLISHED -j ACCEPT
#-A FORWARD -j NFQUEUE --queue-num=4
-A INPUT -p icmp -j ACCEPT
-A INPUT -i lo -j ACCEPT
-A INPUT -p tcp -m state --state NEW -m tcp --dport 22 -j ACCEPT
-A INPUT -p tcp -m state --state NEW -m tcp --dport 80 -j ACCEPT
-A INPUT -p tcp -m state --state NEW -m tcp --dport 443 -j ACCEPT
-A INPUT -j REJECT --reject-with icmp-host-prohibited
-A FORWARD -j REJECT --reject-with icmp-host-prohibited
COMMIT
# Completed on Sun May 15 10:17:00 2022

"/etc/iptables/rules.v4" 25L, 861B
```

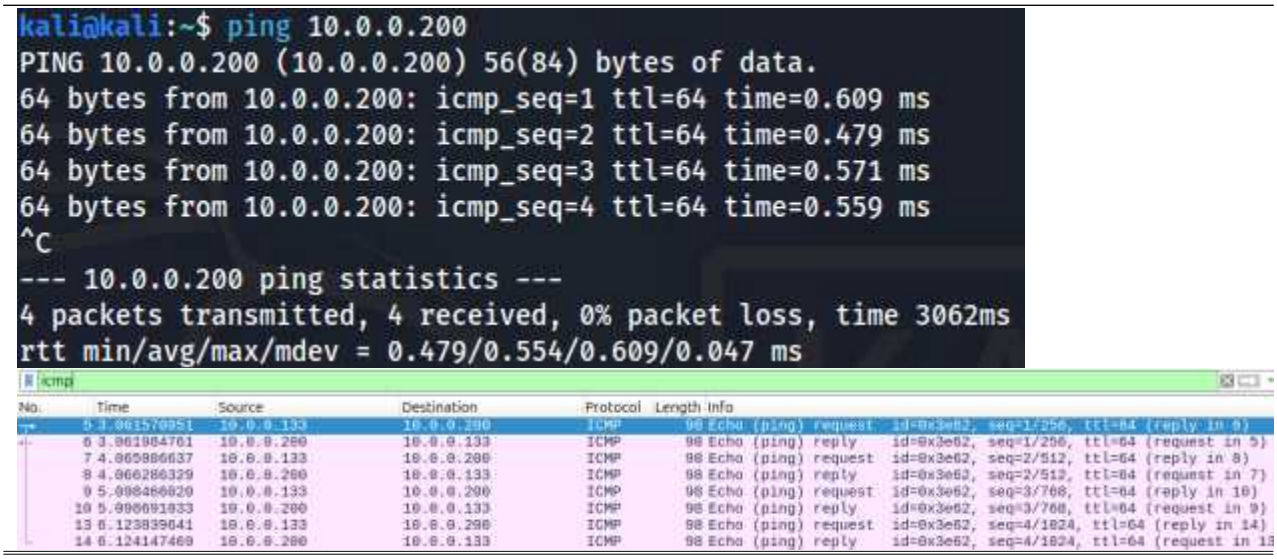
4. 방화벽 구현 확인

10.0.0.222로 로키에 접속하려 했을 때 접속이 되지 않고 Wireshark에 목적지로 가지 못했다는 ICMP 로그가 뜬다.



5. 로키로 핑이 가는지 확인

포트만 REJECT 했으니 로키로 핑은 가야하므로 핑이 가는지 확인하고 Wireshark 에 핑이 제대로 갔는지 로그를 확인하였다.



나. IPS 기반 외부 네트워크의 내부 서버 Telnet 접속 차단 정책 구현

1. Snort IPS 환경 구성

Snort를 IPS 모드로 동작시키기 위해 snort.conf 파일에서 afpacket 및 policy_mode:inline 옵션을 설정하였다. 또한 queue=4 설정을 통해 iptables의 NFQUEUE와 연동하여 패킷을 실시간으로 검사하도록 구성하였다.

apt install snort*

```
root@roror:/etc/dhcp# cd /etc/snort
root@roror:/etc/snort# cp snort.conf ~
root@roror:/etc/snort# vi snort.conf
```

```
192 config daq: afpacket
193 config daq_mode: inline
194 config daq_var: queue=4
195 config policy_mode: inline
```

2. iptables 및 NFQUEUE 설정

rules.v4 파일에서 NFQUEUE --queue-num=4 정책을 적용하여 FORWARD 트래픽이 Snort IPS를 거치도록 설정하였다. 이를 통해 외부와 내부 서버 간 통신 패킷을 Snort가 분석 및 차단할 수 있도록 구성하였다. 이후 netfilter-persistent reload 명령을 사용하여 변경된 iptables 정책을 시스템에 적용하였다.

vi /etc/iptables/rules.v4

```
*nat
:PREROUTING ACCEPT [0:0]
:POSTROUTING ACCEPT [0:0]
:OUTPUT ACCEPT [0:0]
-A POSTROUTING -s 192.168.123.0/24 -o ens33 -j MASQUERADE
#-A POSTROUTING -s 10.0.0.0/24 -o enp0s6 -j SNAT --to-source 192.168.64.12
#-A PREROUTING -d 10.0.0.222 -p TCP --dport 22022 -j DNAT --to 192.168.123.102:22
-A PREROUTING -d 10.0.0.222 -p TCP --dport 22:443 -j DNAT --to 192.168.123.102
COMMIT

*filter
:INPUT DROP [0:0]
:FORWARD ACCEPT [0:0]
:OUTPUT ACCEPT [66:8043]
-A INPUT -m state --state RELATED,ESTABLISHED -j ACCEPT
-A FORWARD -j NFQUEUE --queue-num=4
-A INPUT -p icmp --icmp-type echo-request -j NFQUEUE --queue-num=4
-A INPUT -p icmp -j ACCEPT
-A INPUT -i lo -j ACCEPT
-A INPUT -p tcp -m state --state NEW -m tcp --dport 22 -j ACCEPT
#-A INPUT -j REJECT --reject-with icmp-host-prohibited
#-A FORWARD -j REJECT --reject-with icmp-host-prohibited
COMMIT
```

```
root@roror:/etc/snort/rules# netfilter-persistent reload
run-parts: executing /usr/share/netfilter-persistent/plugins.d/15-ip4tables start
run-parts: executing /usr/share/netfilter-persistent/plugins.d/25-ip6tables start
```

3. Telnet 차단 정책 적용 및 테스트

local.rules 파일에 Telnet 차단 룰을 추가하여 특정 Telnet 트래픽 발생 시 패킷을 차단하도록 설정하였다. 이후 Kali 시스템에서 내부 서버로 Telnet 접속을 시도한 결과 연결이 차단되었으며, Snort 콘솔 로그를 통해 IPS 기반 실시간 차단 기능이 정상적으로 동작함을 확인하였다.

root@roror:/etc/snort/rules# vi local.rules

```
# $Id: local.rules,v 1.11 2004/07/23 20:15:44 bmc Exp $
# ----------------
# LOCAL RULES
# ----------------
# This file intentionally does not come with signatures.  Put your local
# additions here.
#alert icmp  any any -> 10.0.0.200 any (msg:"ToDetected Dos";threshold:type both,track by_dst, count
 30,seconds 2; sid:2018050504;)
drop tcp any any -> any 22 (msg:"ToDetected Telnet"; content:"Telnet"; sid:2018050505;)
#alert tcp any any -> any 23 (msg:"ToDetected SSH"; flags:S; sid:2026050501;)
```

```
kali@kali:~$ telnet 10.0.0.200
Trying 10.0.0.200...
telnet: Unable to connect to remote host: 호스트로 갈 루트가 없음
```

```
root@roror:/etc/snort# snort -Q --daq afpacket -i ens33:ens36 -A console -q -u snort -g snort -c /et
c/snort/snort.conf
05/22-08:37:31.002295  [**] [1:485:4] ICMP Destination Unreachable Communication Administratively Pr
ohibited [**] [Classification: Misc activity] [Priority: 3] {ICMP} 10.0.0.200 -> 10.0.0.133
^C*** Caught Int-Signal
```

다. IDS/IPS 모니터링 및 탐지 시스템을 구동하는 스크립트

1. 변수 선언 및 run_snort() 함수

스크립트 상단에서는 현재 적용 중인 IDS/IPS 모드를 저장하기 위한 MODE_FILE 변수를 선언한다. 이후 run_snort() 함수에서는 사용자가 선택한 Snort 설정 파일과 추가 옵션을 받아 Snort를 실행하도록 구성되어 있다. 실행 전 killall -9 snort 명령을 이용하여 기존 Snort 프로세스를 종료하며, screen 세션을 사용하여 Snort가 백그라운드에서 지속적으로 동작하도록 설정하였다.

```
#!/bin/bash

MODE_FILE="/tmp/snort_current_mode"  # 현재 모드 저장 파일

run_snort() {
    local config_file=$1
    local additional_opts=$2
    echo "Snort 실행: $config_file"
    xterm -fg black -bg white -fn *-fixed-*-*-*-20-* -e \
        "echo \"snort $additional_opts -c $config_file\"; \
        snort $additional_opts -c $config_file; bash"
    killall -9 snort
}
```

2. apply_mode_if_changed() 함수

apply_mode_if_changed() 함수는 현재 시스템에 적용된 모드와 새로 선택한 모드를 비교하여, 변경이 필요한 경우에만 네트워크 설정과 방화벽 정책을 적용하도록 구성되어 있다. IDS 모드 선택 시 IDS 전용 network 설정 파일과 iptables 규칙을 복사하며, IPS 모드 선택 시 IPS 전용 설정 파일과 차단 정책을 적용한다. 이후 systemctl restart systemd-networkd 및 netfilter-persistent reload 명령을 통해 변경된 네트워크 및 방화벽 정책을 시스템에 반영한다.

```
apply_mode_if_changed() {
    local new_mode=$1       # "IDS" or "IPS"
    local current_mode=$(cat "$MODE_FILE" 2>/dev/null)

    if [ "$current_mode" = "$new_mode" ]; then
        echo "[$new_mode] 이미 적용된 모드입니다. 네트워크 설정 생략."
    else
        echo "[$new_mode] 모드 변경 감지 → 네트워크 설정 적용 중..."
        if [ "$new_mode" = "IDS" ]; then
            cp -af "/root/backup/network/ids/20-ens36.network" /etc/systemd/network/
            cp -af "/root/backup/iptables/ids/rules.v4" /etc/iptables/
        else
            cp -af "/root/backup/network/ips/20-ens36.network" /etc/systemd/network/
            cp -af "/root/backup/iptables/ips/rules.v4" /etc/iptables/
        fi
        systemctl restart systemd-networkd
        netfilter-persistent reload
        echo "$new_mode" > "$MODE_FILE"   # 현재 모드 저장
        echo "[$new_mode] 네트워크 설정 완료"
    fi
}
```

3. 메뉴 선택 및 Snort 실행 부분

스크립트 마지막 부분에서는 사용자에게 IDS/IPS 실행 메뉴를 제공한다. 사용자가 번호를 입력하면 case 문을 통해 해당 모드가 실행된다. 1번과 2번은 IDS 모드로 동작하며 각각 기본 Snort 룰과 로컬 룰을 사용한다. 3번은 IPS 모드로 실행되며 -Q 옵션을 사용하여 Inline 방식의 실시간 패킷 차단 기능을 수행한다. 또한 -i ens33:ens36 옵션을 통해 두 네트워크 인터페이스 간의 트래픽을 분석 및 제어하도록 설정되어 있다.

```
echo "
 1) Roror's Snort Rules  [IDS/IPS]
 2) Roror's Local Rules  [IDS/IPS]
 3) Roror's IPS          [IPS/IPS]
"
read -p "choice : " num

case "$num" in
    1)
        apply_mode_if_changed "IDS"
        run_snort "/etc/snort/snort.conf" "-A console -Q -q -u snort -g snort"
        ;;
    2)
        apply_mode_if_changed "IDS"
        run_snort "/etc/snort/snort_local.conf" "-A console -Q -q -u snort -g snort"
        ;;
    3)
        apply_mode_if_changed "IPS"
        run_snort "/etc/snort/snort_ips.conf" "-Q -A console -q -u snort -g snort -i ens33:ens36 -N"
        ;;
    *)
        echo "잘못된 선택입니다."
        ;;
esac
```

라. IDS/IPS 이용하여 악성코드 탐지

1. 스팸 이메일을 통해 Pikabot 악성코드에 감염되는 시나리오

1) TA577은 주로 스팸 이메일을 통해 초기 침투를 시도하는 위협 그룹이며 다양한 악성코드 유포에 관여했으며, 이 시점에서는 Pikabot을 배포하였다.
2) Pikabot: 비교적 새로운 멀웨어로, 백도어 기능을 가지고 있으며, 감염된 호스트에 원격 제어, 페이로드 다운로드, 정보 유출 등의 기능 수행한다.

▷ 탐지 방법

1) Statistics > Protocol Hierarchy → 전체 트래픽 구성 (HTTP, TLS, DNS 등)

Protocol	Percent Packets	Packets	Percent Bytes	Bytes	Bits/s	End Packets	End Bytes	End Bits/s	PDUs
Frame	100.0	8240	100.0	4159223	3,603	0	0	0	8240
Ethernet	100.0	8240	3.3	139248	120	0	0	0	8240
Internet Protocol Version 4	97.3	8018	3.9	160360	138	0	0	0	8018
User Datagram Protocol	2.2	179	0.0	1432	1	0	0	0	179
Simple Service Discovery Protocol	0.0	4	0.0	704	0	4	704	0	4
NetBIOS Name Service	0.3	24	0.0	1200	1	24	1200	1	24
NetBIOS Datagram Service	0.2	13	0.1	2613	2	0	0	0	13
SMB (Server Message Block Protocol)	0.2	13	0.0	1547	1	0	0	0	13
SMB MailSlot Protocol	0.2	13	0.0	325	0	0	0	0	13
Microsoft Windows Browser Protocol	0.2	13	0.0	429	0	13	429	0	13
Domain Name System	1.7	138	0.3	14317	12	138	14317	12	138
Transmission Control Protocol	95.1	7839	92.2	3833133	3,321	5548	2581106	2,236	7839
Transport Layer Security	27.0	2228	90.1	3745629	3,245	2228	2987155	2,588	2355
Hypertext Transfer Protocol	0.4	32	0.9	36264	31	27	7634	6	32
Online Certificate Status Protocol	0.0	1	0.0	471	0	1	471	0	1
Line-based text data	0.0	3	0.1	3219	2	3	3219	2	3
Data	0.0	1	0.6	24832	21	1	24832	21	1
Data	0.4	31	0.1	4156	3	31	4156	3	31
Address Resolution Protocol	2.7	222	0.2	10212	8	222	10212	8	222

2) Statistics > Conversations → 수상한 IP/Port 상대로 비정상 통신 반복되는지 확인

Address A	Address B	Packets	Bytes	Packets A → B	Bytes A → B	Packets B → A	Bytes B → A	Rel Start	Duration	Bits/s A → B	Bits/s B → A
10.2.8.101	10.2.8.1	138	20 kB	69	6 kB	69	14 kB	0.000000	9217.0626	4 bits/s	12 bits/s
10.2.8.101	10.2.8.255	37	5 kB	37	5 kB	0	0 bytes	6.367790	9142.4100	4 bits/s	0 bits/s
10.2.8.101	13.69.116.104	28	9 kB	14	3 kB	14	6 kB	7356.059520	1.0404	23 kbps	44 kbps
10.2.8.101	13.91.231.123	24	11 kB	14	3 kB	10	9 kB	4582.797593	0.2964	76 kbps	233 kbps
10.2.8.101	13.107.3.254	33	10 kB	16	2 kB	17	8 kB	3777.635726	123.5442	121 bits/s	543 bits/s
10.2.8.101	13.107.18.254	74	22 kB	35	4 kB	39	17 kB	4585.178899	4618.3348	7 bits/s	29 bits/s
10.2.8.101	13.107.42.14	31	9 kB	15	2 kB	16	7 kB	435.090097	126.9993	114 bits/s	434 bits/s
10.2.8.101	13.107.42.254	37	11 kB	18	2 kB	19	9 kB	3968.688308	126.8431	141 bits/s	537 bits/s
10.2.8.101	13.107.138.254	33	4 kB	16	2 kB	17	2 kB	4584.853424	126.1479	128 bits/s	129 bits/s
10.2.8.101	13.107.219.66	111	52 kB	43	6 kB	68	46 kB	4027.032518	70.3338	699 bits/s	5,200 bits/s
10.2.8.101	13.107.246.57	74	23 kB	42	4 kB	32	19 kB	3968.941387	5234.1143	6 bits/s	28 bits/s
10.2.8.101	13.107.246.254	42	11 kB	26	2 kB	16	9 kB	2018.432984	1751.1569	11 bits/s	40 bits/s
10.2.8.101	13.107.253.254	26	4 kB	13	2 kB	13	2 kB	681.269857	124.1196	119 bits/s	115 bits/s
10.2.8.101	20.7.1.246	365	44 kB	192	19 kB	173	26 kB	4348.784428	4879.0292	30 bits/s	41 bits/s
10.2.8.101	20.42.65.90	28	10 kB	15	5 kB	13	6 kB	5556.073150	0.3817	97 kbps	121 kbps
10.2.8.101	20.42.65.91	65	23 kB	35	11 kB	30	12 kB	155.935839	3600.6826	24 bits/s	26 bits/s
10.2.8.101	20.44.10.122	24	9 kB	13	3 kB	11	6 kB	1955.948007	0.2833	84 kbps	156 kbps
10.2.8.101	20.50.201.201	96	33 kB	55	11 kB	41	22 kB	3773.964140	5413.7361	16 bits/s	33 bits/s
10.2.8.101	20.99.185.48	29	11 kB	17	3 kB	12	8 kB	150.740820	60.3633	390 bits/s	1,003 bits/s
10.2.8.101	20.106.86.13	24	7 kB	13	2 kB	11	5 kB	1379.947420	0.4507	34 kbps	88 kbps
10.2.8.101	20.140.147.200	28	8 kB	15	2 kB	13	6 kB	3968.353314	125.9142	114 bits/s	365 bits/s
10.2.8.101	20.189.173.18	119	78 kB	76	61 kB	43	17 kB	3976.792662	445.1660	1,105 bits/s	304 bits/s
10.2.8.101	20.211.142.183	21	7 kB	11	2 kB	10	5 kB	5079.229111	1.0607	14 kbps	37 kbps
10.2.8.101	20.246.247.192	26	12 kB	15	3 kB	11	9 kB	9200.738409	0.3849	60 kbps	180 kbps
10.2.8.101	23.47.48.182	13	2 kB	7	982 bytes	6	886 bytes	99.496223	60.1309	130 bits/s	118 bits/s
10.2.8.101	23.47.50.6	13	2 kB	7	978 bytes	6	893 bytes	3833.121557	60.1646	130 bits/s	118 bits/s
10.2.8.101	23.47.50.13	13	2 kB	7	982 bytes	6	888 bytes	3816.074993	76.3986	102 bits/s	92 bits/s
10.2.8.101	23.47.50.16	10	2 kB	5	862 bytes	5	828 bytes	9217.064211	0.1531	45 kbps	43 kbps
10.2.8.101	23.96.180.109	32	13 kB	17	3 kB	15	9 kB	4159.513041	0.6073	45 kbps	121 kbps
10.2.8.101	23.198.7.166	467	286 kB	268	243 kB	199	43 kB	430.140286	1710.0134	1,136 bits/s	203 bits/s
10.2.8.101	23.198.7.167	865	497 kB	471	390 kB	394	107 kB	3772.881535	5433.3563	574 bits/s	157 bits/s
10.2.8.101	23.198.7.175	31	10 kB	16	4 kB	15	7 kB	150.718906	60.3142	487 bits/s	895 bits/s
10.2.8.101	40.100.22.18	29	8 kB	17	2 kB	12	6 kB	2018.655433	127.5473	121 bits/s	381 bits/s
10.2.8.101	40.126.28.21	34	22 kB	16	6 kB	18	16 kB	5078.377711	0.2980	173 kbps	423 kbps
10.2.8.101	40.126.28.22	66	45 kB	32	13 kB	34	31 kB	2931.758468	1.3197	78 kbps	190 kbps
10.2.8.101	40.126.29.6	33	23 kB	16	7 kB	17	17 kB	4159.161644	0.2698	194 kbps	496 kbps
10.2.8.101	40.126.29.13	33	22 kB	16	7 kB	17	16 kB	1379.589397	0.3041	173 kbps	415 kbps
10.2.8.101	40.126.29.14	34	23 kB	18	7 kB	16	16 kB	4349.101991	0.1700	310 kbps	770 kbps
10.2.8.101	52.108.8.254	33	4 kB	16	2 kB	17	2 kB	4585.063125	122.4545	132 bits/s	134 bits/s

3) Right-click → Follow TCP Stream → 의심되는 흐름을 글로 읽듯 따라가기 (추론)

2. 시나리오 흐름 요약

1) 초기 침투

공격자는 스팸 이메일을 이용하여 피해자에게 악성 링크 또는 첨부파일을 전달하였다. 사용자가 이메일 내부의 링크를 클릭하면 외부 서버로 접속이 발생하며, 해당 서버에서는 실행 파일 대신 ZIP 형태의 압축 파일을 제공하였다. 이는 보안 솔루션의 탐지를 우회하기 위한 것이다.

2) 1차 드로퍼 다운로드

피해자는 Qft.zip 파일을 다운로드하게 되면서 압축 파일 내부에 악성 JavaScript 파일과 정상 문서로 위장된 Decoy 파일이 포함되어 있었다. 사용자가 .js 파일을 실행하면 악성 스크립트가 동작하며, 동시에 정상 문서를 실행하여 사용자의 의심을 최소화하는 방식을 사용한다.

3) PowerShell 기반 2차 페이로드 다운로드

악성 JavaScript는 백그라운드에서 PowerShell을 호출하여 외부 서버와의 통신을 수행하였다. 이후 .dat 확장자로 위장된 추가 파일을 다운로드하였으며, 이는 실행 파일에 대한 보안 탐지를 우회하기 위한 목적으로 분석된다. 또한 PowerShell을 악용하여 Windows 기본 기능을 이용하는 공격 기법이 사용되었다.

4) PowerShell 기반 2차 페이로드 다운로드

다운로드된 .dat 파일은 실제로는 PE 형식의 실행 파일이며, 메모리에 로드된 이후 실행된다. 악성코드는 정상 프로세스에 인젝션을 수행할 가능성이 있으며, 레지스트리 Run Key 등을 이용하여 시스템 재부팅 이후에도 자동 실행이 가능하도록 지속성을 확보한다.

5) C2 통신 및 백도어 형성

감염 이후 Pikabot은 공격자의 C2(Command & Control) 서버와 TLS 기반의 암호화 통신을 수행한다. 이 과정에서 주기적인 Beaconing 통신이 발생하며, Self-Signed 인증서를 사용하는 특징이 나타날 수 있다. 또한 공격자는 감염된 시스템을 원격으로 제어할 수 있으며, 추가 악성코드 다운로드, 키로깅, 정보 탈취 등의 악성 행위를 수행할 가능성이 있다.

3. 패킷 분석 포인트

1) DNS 분석을 통해 외부 도메인 조회 여부 확인

감염 시스템은 특정 외부 서버와의 통신을 위해 반복적인 DNS 질의를 수행하였으며, 일부 도메인은 비정상적인 경로 및 난수 기반 URI를 사용하는 특징이 있었다. 이런 방식은 보안 장비의 탐지를 우회하기 위한 기법으로 분석된다.

2) TCP 분석을 통해 감염 시스템이 특정 외부 IP와 지속적으로 연결을 유지 확인

주기적인 연결 시도가 발생하는 Beaconing 패턴이 관찰되었으며, 이는 C2(Command & Control) 서버와의 지속적인 통신할 가능성이 있다.

3) TLS 암호화 통신 분석을 통해 HTTPS 기반의 암호화 통신이 수행 확인

JA3 해시값 및 SNI(Server Name Indication) 정보를 통해 악성 서버 추적이 가능하였으며, Self-Signed 인증서 사용 가능성 또한 존재한다. 이는 공격자가 통신 내용을 은닉하기 위해 TLS 기반 암호화 채널을 사용하였다.

4) HTTP 분석을 통해 비정상적인 URI 요청이 확인

클라이언트가 무작위 난수 파라미터가 포함된 경로(/pgdfga//?5DSb=... 및 /tJWz9/0.52...dat)로 요청을 보냈다. 이는 보안 솔루션의 URL/확장자 기반 탐지를 우회하기 위한 수법이다.

5) Follow TCP Stream 분석을 통해 특정 세션의 전체 데이터 흐름을 추적

악성 파일 다운로드 과정, HTTP 요청 및 응답 데이터, 그리고 외부 서버와의 통신 흐름을 확인할 수 있다.

4. 감염된 피해자(Victim) 측면 시나리오

피해자는 스팸 이메일 내부의 악성 링크 또는 첨부파일을 실행하였으며, 이 과정에서 Qft.zip 파일이 다운로드되었다. 사용자는 별도의 경고 없이 파일을 실행하게 되었고, 내부의 악성 JavaScript가 동작하면서 백그라운드에서 PowerShell을 통해 추가 파일이 자동 다운로드되었다.

다운로드된 Pikabot 페이로드는 메모리에 로드되어 정상 프로세스에 인젝션(Injection)된 상태로 실행되며, 레지스트리 Run Key 등을 이용하여 지속성(Persistence)을 확보한다.

이후 감염 시스템은 DNS 질의를 통해 외부 서버와 연결하고, TLS 기반 암호화 통신을 이용하여 C2(Command & Control) 서버와 비코닝(Beaconing) 통신을 수행한다. 공격자는 이를 통해 원격 명령 수행, 정보 수집, 추가 악성코드 다운로드 등의 악성 행위를 수행할 수 있다.

5. 분석 디스플레이 필터

1) 1차 드로퍼(ZIP) 통신 탐색:
   http.request.method == "GET" && http.host == "orangebrands.co.tz"
2) 2차 페이로드(.dat) 통신 탐색:
   http.request.method == "GET" && http.host == "gloverstech.com" && http.user_agent contains "PowerShell"
3) 특정 확장자 다운로드 전역 탐지:
   http.request.uri matches "(?i)₩₩.(zip|exe|dat)"

6. 의심 패킷 분석(번호)

No.21 패킷

```
GET /pgdfga//?5DSb=1707413069 HTTP/1.1
Host: orangebrands.co.tz
Connection: keep-alive
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/121.0.0.0 Safari/537.36 Edg/121.0.0.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3
;q=0.7
Referer: http://orangebrands.co.tz/pgdfga/
Accept-Encoding: gzip, deflate
Accept-Language: en

HTTP/1.1 200 OK
Date: Thu, 08 Feb 2024 17:24:30 GMT
Server: Apache
Content-Description: File Transfer
Content-Disposition: attachment; filename=Qft.zip
Content-Transfer-Encoding: binary
Connection: Keep-Alive, Keep-Alive
Expires: 0
Cache-Control: must-revalidate, post-check=0, pre-check=0
Pragma: public
Upgrade: h2,h2c
Connection: Upgrade
Vary: Accept-Encoding
Content-Encoding: gzip
Keep-Alive: timeout=5, max=75
Transfer-Encoding: chunked
Content-Type: application/octet-stream
```

① ZIP 파일 강제 다운로드

"Content-Disposition: attachment; filename=Qft.zip"

-> 브라우저에 "파일 다운로드"를 강제로 유도.

② 의심스러운 URI 구조

"/pgdfa/r/75DS-1707413069"

- 의미 없는 디렉터리명 `pgdfa`
- 랜덤 토큰형 URI
- epoch timestamp 비슷한 숫자 포함

No.107 패킷

```
GET /tJWz9/0.526635390798647.dat HTTP/1.1
User-Agent: Mozilla/5.0 (Windows NT; Windows NT 10.0; en-US) WindowsPowerShell/5.1.19041.3930
Host: gloverstech.com
Connection: Keep-Alive

HTTP/1.1 301 Moved Permanently
Date: Thu, 08 Feb 2024 17:26:00 GMT
Server: Apache/2.4.41 (Ubuntu)
Location: https://gloverstech.com/tJWz9/0.526635390798647.dat
Content-Length: 340
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/html; charset=iso-8859-1

<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>301 Moved Permanently</title>
</head><body>
<h1>Moved Permanently</h1>
<p>The document has moved <a href="https://gloverstech.com/tJWz9/0.526635390798647.dat">here</a>.</p>
<hr>
<address>Apache/2.4.41 (Ubuntu) Server at gloverstech.com Port 80</address>
</body></html>
```

① PowerShell User-Agent

"User-Agent: Mozilla/5.0 (Windows NT; Windows NT 10.0; en-US) WindowsPowerShell/5.1"

일반 브라우저가 아니라 악성 다운로드 스크립트일 가능성이 있음.

② '.dat' 위장 파일

"0.526635390798647.dat"

.dat는 자주 악용되고 실제 내부는 악성 파일일 수 있음.

특히 랜덤 float 값 파일명은 자동 생성형 드로퍼 특징과 유사.

7. 실시간 탐지(snort 룰)

탐지 룰 1) 악성 ZIP 드로퍼(Qft.zip) 파일 전송 탐지 (매직 넘버 PK 검사)

alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"MALWARE-DROP Pikabot Suspected ZIP Payload Transfer Detected"; flow:to_client,established; file_data; content:"|50 4B 03 04|"; at_offset:0; sid:1000006; rev:1;)

- `alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any`
  외부 네트워크에서 내부 네트워크로 유입되는 TCP 기반 HTTP 트래픽을 탐지 대상으로 설정한다. 즉, 외부 서버가 내부 사용자에게 전달하는 HTTP 응답 데이터를 검사한다.
- `msg:"MALWARE-DROP Pikabot Suspected ZIP Payload Transfer Detected"`
  탐지 발생 시 출력되는 경고 메시지이다. Pikabot 관련 의심 ZIP 파일 전송이 탐지되었음을 의미한다.
- `flow:to_client,established`
  서버에서 클라이언트 방향으로 전달되는 정상적으로 수립된 TCP 세션만 검사한다. 즉, HTTP 응답(Response) 패킷을 분석 대상으로 설정한다.
- `file_data`
  HTTP 헤더 영역이 아닌 실제 파일 데이터(payload) 영역을 검사하도록 지정한다. 따라서 다운로드되는 파일의 실제 내용 분석이 가능하다.
- `content:"|50 4B 03 04|"`
  ZIP 파일의 매직 넘버(Signature)를 탐지한다. `50 4B 03 04`는 ZIP 파일 시작 부분에 존재하는 고유 식별값으로, ASCII 기준 `PK`를 의미한다.
- `at_offset:0`
  파일 데이터의 시작 위치(0 byte offset)에서만 시그니처를 검사한다. 즉, 파일 맨 앞부분이 ZIP 헤더와 일치하는 경우에만 탐지한다.
- `sid:1000006`
  Snort 룰의 고유 식별 번호(Snort ID)이다. 탐지 이벤트 관리 및 룰 식별에 사용된다.
- `rev:1`
  룰의 수정 버전(Revision)을 의미한다. 현재 해당 룰의 첫 번째 버전임을 나타낸다.

탐지 룰 2) PowerShell을 이용한 비정상 확장자(.dat) 페이로드 다운로드 탐지

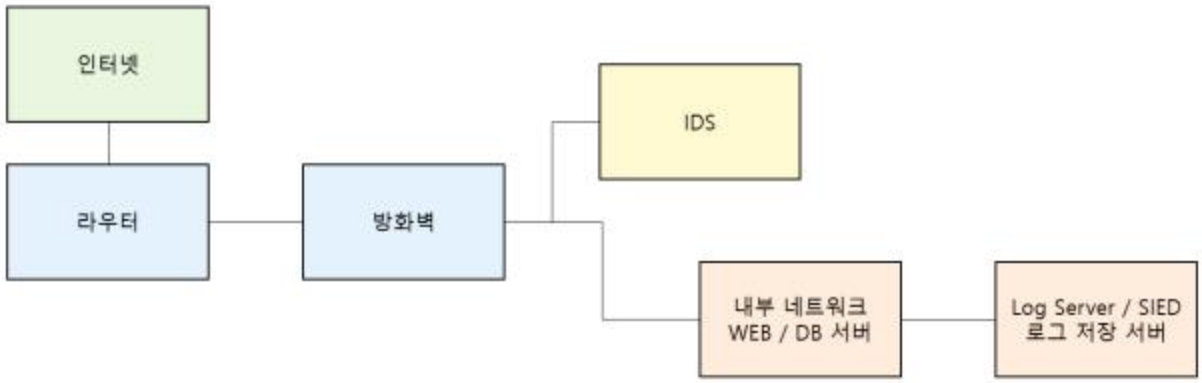
```
alert tcp $HOME_NET any -> $EXTERNAL_NET $HTTP_PORTS (msg:"MALWARE-DROP Pikabot Payload Download via PowerShell Detected"; flow:to_server,established; content:"GET"; http_method; content:".dat"; http_uri; content:"PowerShell"; http_header; classtype:trojan-activity; sid:1000007; rev:1;)
```

- `alert tcp $HOME_NET any -> $EXTERNAL_NET $HTTP_PORTS`
  내부 네트워크에서 외부 HTTP 서버로 전달되는 TCP 트래픽을 탐지 대상으로 설정한다. 즉, 내부 시스템의 외부 HTTP 요청(Request)을 검사한다.
- `msg:"MALWARE-DROP Pikabot Payload Download via PowerShell Detected"`
  탐지 발생 시 출력되는 경고 메시지이다. PowerShell을 이용한 Pikabot 관련 추가 페이로드 다운로드 행위를 의미한다.
- `flow:to_server,established`
  클라이언트에서 서버 방향으로 전달되는 정상적으로 수립된 TCP 세션만 검사한다. 즉, HTTP 요청(Request) 패킷을 분석 대상으로 설정한다.
- `content:"GET"; http_method;`
  HTTP 메서드(Method)가 GET 방식인지 검사한다. 즉, 파일 다운로드 요청 여부를 확인한다.
- `content:".dat"; http_uri;`
  HTTP URI 내부에 `.dat` 문자열이 포함되어 있는지 검사한다. 예를 들어 `/payload.dat` 형태의 요청을 탐지한다.
- `content:"PowerShell"; http_header;`
  HTTP 헤더 내부에 `PowerShell` 문자열 존재 여부를 검사한다. 일반적으로 PowerShell 기반 웹 요청은 `User-Agent: PowerShell/5.1` 형태를 사용한다.
- `classtype:trojan-activity`
  탐지 이벤트를 트로이목마 활동(Trojan Activity) 유형으로 분류한다. 이를 통해 보안 장비 내 우선순위 분류가 가능하다.
- `sid:1000007`
  Snort 룰의 고유 식별 번호(Snort ID)이다.
- `rev:1`
  룰의 수정 버전을 의미하며 현재 첫 번째 버전임을 나타낸다.

Ⅳ. 보안 시스템 장애 분석 및 대응 방안 보고서

가. 운영 현황 도식화

· 보안 시스템 구성도



· 각 장비의 위치, 역할, 연동 관계를 표현

장비명	위치	역할	연동 관계
Router	외부망 경계	외부 인터넷 연결	Firewall 연결
Firewall	DMZ 구간	접근제어 및 로그 생성	IDS, Log Server 연동
IDS	방화벽 후단	침입 탐지 및 패킷 분석	Firewall 미러링 수신
Log Server/SIEM	내부망	로그 저장 및 분석	Firewall 로그 수신
WEB/DB 서버	내부망	서비스 운영	Firewall 보호 대상

나. 장애 분석

장애 장비명	장애 징후	장애 원인 유추	장애 유형 분류
IDS	- NIC 또는 NIC 버퍼에서 지속적인 패킷 드랍(Drop) 발생 - 탐지율 저하 및 분석 지연 현상 - "Packet Drop" 경고 메시지 증가	- 트래픽 급증: DDoS 공격 또는 내부 대용량 데이터 전송으로 인한 처리 용량 초과 - 자원 고갈: 분석 룰(Rule) 오버헤드로 인한 CPU/ Memory 자원 부족	- 리소스 부족 - 성능 병목 - 설정 오류 - 하드웨어 성능 한계
Firewall / Log Server (SIEM)	- 로그 저장 실패 메시지 반복 출력 - 로컬 로그 유실 및 통합 로그 서버로의 전송 실패 - SIEM 연동 실패	- 디스크 풀(Full): 로컬 스토리지 공간 고갈 - 네트워크 / 인증 오류: 로그 서버 (SIEM)와의 통신 단절 또는 권한(인증) 문제	- 설정 오류 - 리소스 부족 - 네트워크 장애

다. 장애 유형별 대응 방안

① IDS 패킷 드랍 대응 방안

1. **현황 파악 및 자원 모니터링:**
   IDS CLI/GUI 접속 후 top, htop 등의 명령어로 CPU, 메모리, NIC 버퍼 상태를 확인한다.
2. **트래픽 분석 및 유입 차단:**
   백본 스위치에서 유입되는 미러링 트래픽의 양을 확인하고, 불필요한 프로토콜(예: 내부 백업 트래픽)이 포함되어 있다면 미러링 대상에서 제외한다.
3. **시그니처(룰) 최적화 (Tuning):**
   최근 업데이트된 룰 중 과도한 연산을 유발하는 룰(Regex 패턴 등)을 비활성화하거나, 탐지 불필요한 대역(인프라 내부 통신)을 White-list 처리하여 검사 예외를 설정한다.
4. **하드웨어 버퍼 조정:**
   NIC의 Rx 버퍼 사이즈를 최대치로 상향 조정하여 패킷 드랍을 완화한다.

② 방화벽 로그 저장 실패 대응 방안

1. **디스크 공간 확보 (긴급):**
   방화벽 로컬 디스크 상태를 확인(df -h)하고, 오래된 임시 파일이나 불필요한 코어덤프(Core dump) 파일을 삭제하여 최소 공간을 확보한다.
2. **로그 로테이션(Rotation) 및 백업 주기 재설정:**
   로그 보존 기간을 단축하고, 주기적으로 자동 압축 및 외부 백업 후 로컬에서 삭제되도록 설정을 변경한다.
3. **로그 서버 연동 상태 점검:**
   통합 로그 서버(SIEM)와의 통신(UDP/TCP 514 포트 등) 상태를 점검하고, 방화벽 및 로그 서버 간의 방화벽 허용 정책이나 인증 토큰을 갱신한다.

라. 장애 보고서 작성

1. 개요

일시: 2026년 5월 15일 10:03 ~ 15:11 (약 5시간)
대상 장비: 내부 침입 탐지 시스템(IDS), 외부 방화벽
장애 현황: IDS의 지속적인 패킷 드랍으로 인한 보안 사각지대 발생, 방화벽 로그 저장 실패로 인한 감사 추적 불가 위험 노출

2. 원인 분석

장애 항목	원인
IDS 패킷 드랍	최근 유입 트래픽 급증 및 과도한 미러링 패킷 유입으로 인한 분석 엔진 CPU/메모리 고갈
로그 저장 실패	로그 저장용 로컬 디스크 공간 100% 도달 및 외부 SIEM 서버와의 일시적 세션 단절로 인한 로그 드랍

3. 조치 내용

항목	조치 결과
IDS	불필요한 유입 트래픽(내부 백업망) 미러링 제외 처리 및 미사용 시그니처 300여 개 비활성화 롤 최적화 완료
Firewall	오래된 로컬 로그 수동 삭제로 디스크 공간 확보
Log Server	SIEM 서버 연동 프로세스 재시작 및 정상 전송 확인 완료

마. 재발 방지 대책

① IDS 패킷 드랍 예방 방안

- 하드웨어 Scale-up/out 검토: 지속적인 트래픽 증가 추세를 반영하여, 고성능 NIC 도입 및 고사양 장비로의 교체 혹은 로드밸런싱을 통한 IDS 분산 배치를 검토합니다.
- 정기적인 룰 튜닝 프로세스 정립: 월 1회 이상 미탐/오탐 및 리소스 과다 유발 룰을 분석하여 비활성화하는 '시그니처 최적화 기간'을 운영합니다.

② 방화벽 로그 저장 실패 예방 방안

- 임계치 기반 알람(Alert) 설정: 방화벽 디스크 사용량이 75% 초과 시 SMS 및 이메일로 관제 담당자에게 즉시 알람이 발송되도록 설정합니다.
- 로그 이중화 및 전송 검증 자동화: 로컬 저장을 최소화하고, Primary/Secondary Syslog 서버를 지정하여 이중화 전송 체계를 구축합니다. 전송 실패 시 큐(Queue)에 임시 보관 후 자동 재전송하는 메커니즘을 적용합니다.